

Universidad Complutense de Madrid

Máster en Ciberseguridad

Trabajo de Fin de Máster

MalWhere

Una tubería automatizada y auditable para la
extracción de inteligencia de amenazas a partir de muestras de malware

Autor: Martín López Aramburu

Tutores: Prof. Javier Domínguez Gómez
Prof. Román Ramírez Giménez

Curso académico 2025–2026

Índice

Resumen	1
1. Introducción	2
1.1. Motivación	2
1.2. Planteamiento del problema	2
1.3. Contribuciones	2
1.4. Estructura del documento	3
2. Trabajo relacionado	3
2.1. Análisis dinámico basado en sandbox	3
2.2. Mapeo estático a ATT&CK	4
2.3. Extracción automática desde informes de amenazas	4
2.4. Agregadores de reputación y escáneres multimotor	4
2.5. Estándares de intercambio de inteligencia de amenazas	5
2.6. Posicionamiento	5
3. Arquitectura del sistema	5
3.1. Visión general de la tubería	5
3.2. Motor de análisis estático	6
3.3. Motor de análisis dinámico	6
3.4. Reconciliación de confianza	7
3.4.1. Extensión entre niveles	7
3.5. El bucle de reenvío	8
3.6. Ampliación de la cobertura de reglas de detección	9
3.7. Despliegue y reproducibilidad	9
4. Evaluación	10
4.1. Metodología	10
4.2. Resultados	11
4.3. La auditoría de falsos positivos	12
4.4. Calibración de confianza	13
5. Casos de estudio	13
5.1. La cadena multietapa de RoningLoader	13
5.2. El error de agregación del instalador	13
5.3. El hueco de verdad de referencia de WhiteSnakeStealer	14
5.4. La cascada de falsos positivos de la clave XOR	14
6. Limitaciones	15
7. Trabajo futuro	16
8. Conclusión	17
Referencias	18
A. Ampliación de cobertura de reglas de detección	18

Resumen

Los equipos de operaciones de seguridad dependen de inteligencia de amenazas estructurada (IOCs, mapeos a MITRE ATT&CK, artefactos listos para STIX/MISP) para actuar rápidamente sobre los hallazgos de malware. Los agregadores de reputación amplios como VirusTotal entregan esa estructura a una escala enorme, pero no reconcilian sus muchas señales entre sí, de modo que producir un mapeo de técnica defendible y ligado a evidencia para una muestra concreta todavía suele recaer en un analista de ingeniería inversa que traza el código manualmente y redacta un informe. Esta tesis presenta **MalWhere**, una tubería modular que combina ingeniería inversa estática y detonación dinámica en sandbox, reconcilia sus hallazgos en mapeos de técnicas MITRE ATT&CK con confianza cuantificada, y exporta el resultado como paquetes STIX 2.1 y eventos MISP en vivo.

La tubería se valida frente a tres familias de malware con arquitecturas distintas: un binario de ransomware (Akira); un cargador multietapa que suelta un driver rootkit, un módulo antiantivirus y un cliente C2 de acceso remoto (RoningLoader); y un infostealer .NET rico en funcionalidades (WhiteSnakeStealer). Cada una cuenta con verdad de referencia obtenida mediante ingeniería inversa manual a nivel de función, verificada con Ghidra, no mediante un escaneo superficial. Dos contribuciones metodológicas van más allá de una tubería estática+dinámica convencional: un modelo de reconciliación de confianza cruzada entre fuentes *y* entre niveles de técnica, que trata una técnica observada tanto por evidencia estática como dinámica, o por una técnica padre y una subtécnica desde fuentes distintas, como una señal más fuerte que cualquiera de las dos por separado; y un *bucle de reenvío* que analiza de forma independiente cada componente que una muestra multietapa suelta o inyecta, sin atribuir erróneamente las capacidades de una carga soltada a la puntuación de confianza del binario padre.

La metodología de evaluación va más allá de la precisión y la exhaustividad en bruto: cada falso positivo encontrado durante la validación se rastreó individualmente hasta su evidencia exacta (una combinación de importaciones concreta, el campo de datos crudo de una firma de sandbox, un patrón de cadena) y se contrastó con el texto completo del informe manual correspondiente, no solo con su tabla resumen. De los 13 falsos positivos encontrados de esta forma en las tres muestras, diez eran errores genuinos de la tubería con causa raíz identificada y corregida, uno era un hueco en cómo se extrajo la verdad de referencia y no un error de la tubería, y dos se dejaron abiertos deliberadamente a la espera de confirmación independiente en lugar de resolverse solo con la evidencia propia de la tubería. La cobertura de detección estática se amplió posteriormente de unas 30 a aproximadamente 85 identificadores de técnica MITRE ATT&CK, cada adición obtenida de las propias descripciones de técnica de MITRE y verificada para no introducir nuevos hallazgos en las muestras validadas antes de confiar en ella.

La tubería resultante alcanza puntuaciones F1 a nivel de familia de 1.00 (Akira), 0.89 (WhiteSnakeStealer) y 0.86 (RoningLoader, contando sus componentes reenviados), con precisión cercana al 100 % en las tres muestras. La tesis argumenta que este rastro de auditoría, cada regla ligada a evidencia verificable, cada error diagnosticado a una causa concreta, cada extensión comprobada frente a regresiones, es lo que hace que el resultado de la tubería sea utilizable precisamente para la decisión que las señales no reconciliadas de un agregador de reputación no pueden sostener por sí solas, y es la propiedad con mayor probabilidad de transferirse a familias de malware que la tubería todavía no ha visto.

Palabras clave: análisis de malware, inteligencia de amenazas, MITRE ATT&CK, STIX, MISP, análisis estático, análisis dinámico, detonación en sandbox, ingeniería inversa, reconciliación de confianza.

Introducción

Motivación

Cuando una muestra de malware llega a un equipo de respuesta a incidentes o de inteligencia de amenazas, el resultado útil rara vez es el propio binario: es un resumen estructurado y accionable de qué indicadores de compromiso (IOCs) presenta, qué técnicas de MITRE ATT&CK [1] implementa, y artefactos listos para alimentar ingeniería de detección (reglas Sigma, firmas YARA) o una plataforma de inteligencia de amenazas como MISP [2]. A menudo ya existe una primera pasada rápida sobre ese resumen: una consulta de hash a un agregador de reputación como VirusTotal devuelve veredictos de proveedores y etiquetas de comportamiento de sandbox en segundos. Lo que esa primera pasada no ofrece es una respuesta *reconciliada*, ya que las muchas señales que muestra se presentan una junto a otra en lugar de contrastarse entre sí, de modo que convertirlas en un mapeo de técnica defendible para una muestra concreta todavía suele significar que un analista humano detona la muestra manualmente en un sandbox, traza su código en un desensamblador y redacta el informe a mano. Ese proceso es riguroso pero lento, y no escala al volumen de muestras que un equipo de operaciones de seguridad encuentra realmente.

Los sandboxes automatizados como CAPE [3] ya producen grandes volúmenes de datos de comportamiento en bruto: trazas de llamadas a API, ficheros soltados, actividad de red, coincidencias de firmas mantenidas por la comunidad. Las herramientas de análisis estático extraen importaciones, cadenas y artefactos de cargas empaquetadas directamente del binario. Lo que generalmente falta es la capa que se sitúa entre estos hallazgos en bruto y algo que un analista o una plataforma consumidora pueda usar directamente: reconciliar evidencia estática y dinámica para la *misma* afirmación, mapear esa evidencia sobre una taxonomía de técnicas estándar con un nivel de confianza defendible, y exportarla en un formato que las plataformas de inteligencia de amenazas ya consumen.

Planteamiento del problema

Tres problemas concretos motivan este trabajo, cada uno identificado al construir y validar la tubería descrita en esta tesis:

1. **Reconciliación de confianza entre fuentes.** Una técnica observada tanto por análisis estático (una combinación de importaciones) como por análisis dinámico (una firma de sandbox) es evidencia más sólida que cualquiera de las dos por separado, pero solo si ambas observaciones se refieren realmente a la misma técnica. Una implementación ingenua que compara observaciones por identificador de técnica exacto pasa por alto el caso habitual en el que una fuente reporta una técnica padre y la otra reporta una subtécnica específica para lo que, en realidad, es el mismo comportamiento.
2. **Malware multietapa.** Un cargador que suelta un driver rootkit, un módulo antiantivirus y un cliente de acceso remoto tiene capacidades reales distribuidas entre varios binarios, no concentradas en el único fichero detonado inicialmente. Fusionar ingenuamente la evidencia de cada componente soltado en la puntuación de confianza propia de la muestra padre atribuiría erróneamente esa capacidad, ya que el comportamiento de la carga soltada no demuestra que el cargador realice ese comportamiento.
3. **Confiar en el resultado.** Una tubería que reporta alta confianza para un hallazgo equivocado es peor que una que no reporta nada, porque engaña activamente a quien consume el resultado. Esto motiva tratar cada regla de detección como una afirmación que necesita evidencia, y cada resultado de evaluación como algo que auditar antes de confiar en él, no solo como una cifra que reportar.

Contribuciones

Esta tesis aporta las siguientes contribuciones, cada una sustanciada en detalle en secciones posteriores:

- Un **modelo de reconciliación de confianza cruzada entre fuentes y entre niveles de técnica** (§3.4) que extiende la regla estándar “ambas fuentes coinciden $\Rightarrow$ confianza alta” para reconocer también la concordancia entre una técnica padre reportada por una fuente y su subtécnica específica reportada por la otra, un hueco confirmado en datos reales de evaluación, no meramente teórico.
- Un **bucle de reenvío** (§3.5) que analiza de forma independiente cada fichero que una muestra multietapa suelta o inyecta durante la detonación, etiquetando cada uno con su linaje hacia la muestra padre sin mezclar su evidencia en la salida de confianza propia de la muestra padre.
- Un **conjunto de reglas de detección estática reproducible y trazable a evidencia** (§3.6), ampliado sistemáticamente de unas 30 a aproximadamente 85 identificadores de técnica MITRE ATT&CK relevantes para Windows, con cada adición trazada a la descripción oficial de MITRE para esa técnica y verificada frente al conjunto de muestras validadas antes de confiar en que no sobreajusta.
- Una **metodología de evaluación y proceso de auditoría** (§4) que va más allá de precisión/exhaustividad: precisión estratificada por nivel de confianza y por acuerdo entre fuentes para comprobar si las propias afirmaciones del modelo de reconciliación se sostienen, y una auditoría sistemática de falsos positivos en la que cada discrepancia entre la salida de la tubería y la verdad de referencia verificada manualmente se diagnosticó individualmente a una causa concreta y verificable antes de corregirse, dejarse abierta, o atribuirse a un hueco en la verdad de referencia.

Estructura del documento

La Sección 2 sitúa este trabajo respecto a las herramientas de sandboxing existentes, los enfoques de mapeo estático a ATT&CK, y agregadores de reputación como VirusTotal. La Sección 3 describe la arquitectura de la tubería de principio a fin. La Sección 4 presenta la metodología de evaluación y los resultados, incluida la auditoría de falsos positivos. La Sección 5 detalla cuatro casos concretos, incluyendo un error arquitectónico real encontrado y corregido a través del proceso de evaluación, que ilustran la disciplina de validación del proyecto con más concreción de lo que permiten las cifras agregadas. La Sección 6 enuncia con precisión las limitaciones de la tubería, cada una ligada a una causa específica diagnosticada. La Sección 7 esboza extensiones concretas, incluyendo una, análisis dinámico Linux/ELF para familias de botnets IoT, evaluada y deliberadamente aplazada por razones explícitas, no implícitas. La Sección 8 concluye. El Anexo A tabula el conjunto de reglas de detección añadidas durante la ampliación de cobertura. El código fuente completo de la tubería se publica en el repositorio público del proyecto en lugar de reproducirse aquí.

Trabajo relacionado

Análisis dinámico basado en sandbox

Los sandboxes automatizados de malware se remontan a Cuckoo Sandbox [4], cuya arquitectura (un controlador que orquesta la detonación dentro de una máquina virtual desechable, con un agente en el huésped que reporta llamadas a API y artefactos de vuelta al host) sigue siendo el patrón estándar. CAPE [3] (Config And Payload Extraction) bifurcó este linaje específicamente para añadir desempaquetado automático y extracción de configuración para familias de malware conocidas, e incluye una amplia biblioteca de firmas de comportamiento mantenida por la comunidad, cada una opcionalmente etiquetada con identificadores de técnica MITRE ATT&CK. Esta tubería se apoya directamente en CAPE para el análisis dinámico (§3.3), y trata sus mapeos de firma a técnica mantenidos por la comunidad como una hipótesis de partida a verificar, no como verdad de referencia a asumir; una distinción sustanciada de forma concreta en §4: varios de los mapeos propios de CAPE se comprobaron frente a su evidencia en bruto y

resultaron ser sistemáticamente demasiado amplios para las muestras en las que se activaron, un paso de inspección que esta tubería realiza y que la mayoría de despliegues de sandbox omiten.

Mapeo estático a ATT&CK

Mapear artefactos estáticos (importaciones, cadenas, coincidencias YARA) directamente a técnicas ATT&CK es una práctica común en productos EDR comerciales y en herramientas de la comunidad. El equivalente de código abierto más cercano es capa, de Mandiant [5], que compara reglas curadas de importaciones, cadenas y patrones de bytes contra un binario para reportar las capacidades que implementa, muchas de ellas ya mapeadas a ATT&CK. La mayoría de reglas de capa, como la mayoría de búsquedas de indicador de un EDR, son coincidencias de un único indicador: basta un nombre de importación o un patrón de cadena para activar la regla. Este proyecto diverge deliberadamente de ese patrón en su modelo de confianza (§3.2): un único indicador genérico (una importación usada para muchos propósitos legítimos) se trata como evidencia más débil que una *combinación coherente* de indicadores que solo tiene sentido en conjunto para la técnica afirmada. Concretamente, `OpenProcess` por sí sola no es evidencia de inyección de proceso (T1055), pero `OpenProcess` junto con `VirtualAllocEx` y `WriteProcessMemory` sí lo es, porque las tres API componen una primitiva reconocible que no tiene otro propósito común. Esto sacrifica parte de la amplitud de capa (que incluye cientos de reglas cubriendo muchas plataformas y clases de capacidad) a cambio de una precisión más estrecha pero respaldada por evidencia en las técnicas de Windows que esta tubería sí cubre, una decisión de compromiso explicitada y medida directamente en §4.3.

Extracción automática desde informes de amenazas

Una línea de trabajo paralela extrae técnicas ATT&CK no de un binario sino de prosa de analista sin estructurar: TTPDrill [6] analiza informes de inteligencia de amenazas con una ontología propia y un pipeline de PLN para recuperar acciones del atacante; TRAM, de MITRE Engenuity [7], y rcATT [8] entrenan ambos clasificadores de texto para etiquetar párrafos de informes CTI con etiquetas de técnica ATT&CK probables. Estas herramientas resuelven un problema genuinamente distinto: ayudan a un analista que ya dispone de un *informe escrito* a convertirlo en etiquetas de técnica estructuradas y legibles por máquina de forma más rápida. Esta tubería, en cambio, deriva sus etiquetas de técnica directamente del propio binario y comportamiento en tiempo de ejecución de la muestra, sin ningún informe como paso intermedio, lo que permite que cada hallazgo lleve asociada una pieza concreta de evidencia verificable (una combinación de importaciones, el campo de datos en bruto de una firma) en lugar de la puntuación de confianza de un clasificador de PLN sobre texto libre. Los dos enfoques son complementarios, no competidores: un clasificador al estilo TRAM podría en principio tomar como texto de entrada los propios casos de estudio escritos por esta tubería (§5), cerrando el ciclo de evidencia binaria a informe y de vuelta a etiquetas de técnica reextraídas.

Agregadores de reputación y escáneres multimotor

VirusTotal [9] es la herramienta a la que primero recurre la mayoría de analistas de respuesta a incidentes, y constituye un punto de comparación útil porque opera en el extremo opuesto del compromiso entre amplitud y profundidad que asume esta tubería. VirusTotal agrega veredictos de decenas de motores antivirus e integraciones de sandbox sobre un corpus de envíos de una escala que ningún pipeline de investigación individual puede igualar, lo que lo hace excelente para el triaje rápido de reputación: si un hash ya es conocido, y si otros proveedores ya lo marcan. Lo que VirusTotal no hace es reconciliar esas señales entre sí para una única afirmación: el veredicto de cada motor y las etiquetas de comportamiento de cada sandbox se muestran uno junto a otro, no se contrastan, de modo que dos etiquetas de técnica contradictorias procedentes de dos integraciones distintas se muestran ambas sin más, sin ningún mecanismo que resuelva cuál de ellas respalda realmente la evidencia en bruto. Esta tubería apunta precisamente a ese hueco, no a la amplitud de VirusTotal: muchas menos muestras, pero cada afirmación de técnica trazada

hasta la combinación de importaciones, el campo de datos de firma o el patrón de cadena exacto que la produjo, la concordancia entre fuentes y entre niveles modelada explícitamente (§3.4), y los componentes soltados por una muestra multietapa analizados y atribuidos de forma individual en lugar de fundirse en un único veredicto agregado para el hash del padre (§3.5). Las dos herramientas no son sustitutas: una consulta a VirusTotal es el primer paso correcto para el triaje a escala, y esta tubería es el siguiente paso correcto una vez que una muestra concreta necesita un mapeo de técnica defendible y ligado a evidencia, no una puntuación de reputación.

Estándares de intercambio de inteligencia de amenazas

STIX 2.1 [10] (Structured Threat Information Expression) y MISP [2] (Malware Information Sharing Platform) son los dos formatos de intercambio a los que exporta esta tubería. STIX define un grafo de objetos tipados (indicadores, malware, patrones de ataque, relaciones) pensado para el intercambio máquina a máquina; MISP es a la vez un modelo de datos y una plataforma en ejecución que la mayoría de organizaciones ya operan. Exportar a ambos, en lugar de producir únicamente un informe legible por humanos, es lo que hace que el resultado de la tubería sea directamente consumible por las herramientas que un equipo de operaciones de seguridad ya utiliza, sin necesidad de transcripción manual.

Posicionamiento

Esta tesis no propone una primitiva de detección novedosa: cada señal individual utilizada (una importación de API, un patrón de cadena, una firma de comportamiento de sandbox) es una técnica bien establecida en la práctica del análisis de malware, y herramientas como capa y CAPE ya exponen muchas de esas mismas señales en bruto. La contribución está en la *integración*: un modelo de reconciliación de confianza que es verificablemente más que la suma de sus fuentes (§3.4), un mecanismo para atribuir correctamente la capacidad distribuida del malware multietapa (§3.5), y, argumentada como la más defendible de las tres, una disciplina de validación en la que cada afirmación que hace la tubería se comprueba frente a evidencia real antes de confiar en ella, documentada con suficiente especificidad como para que la comprobación misma sea reproducible (§4). Posicionada frente a los dos polos revisados arriba, esta tubería se sitúa deliberadamente entre un agregador amplio y no reconciliado como VirusTotal y un informe manual de ingeniería inversa estrecho, de una sola muestra: automatizada y exportadora de estándares como el primero, verificada por evidencia y específica por técnica como el segundo.

Arquitectura del sistema

Visión general de la tubería

La Figura 1 muestra las cinco etapas de la tubería. Una muestra se analiza estática y dinámicamente en paralelo; ambas salidas alimentan un *normalizador* que deduplica IOCs y agrupa las observaciones ATT&CK por técnica; un *mapeador* reconcilia la confianza entre fuentes y produce la lista final de técnicas; un *exportador* convierte esa lista en un paquete STIX 2.1 y/o un evento MISP en vivo. Cada etapa es una herramienta de línea de comandos independiente que opera sobre un esquema JSON bien definido, de modo que la tubería puede ejecutarse de principio a fin o volver a ejecutar cualquier etapa de forma aislada, propiedad utilizada extensamente durante la validación: un solo cambio en una regla de detección a menudo solo requiere volver a ejecutar el mapeador, no la detonación completa en sandbox.

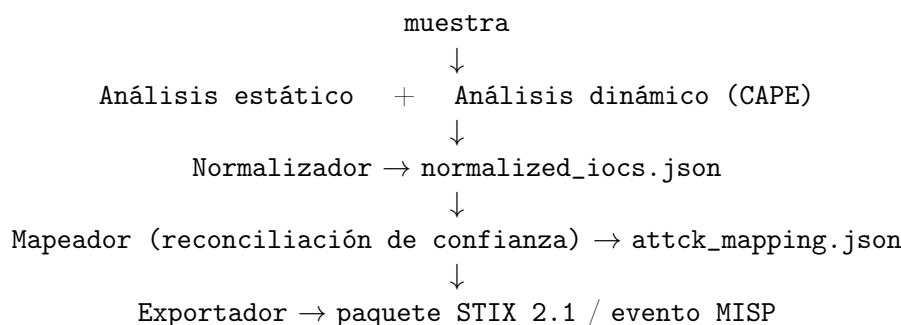


Figura 1: Etapas de la tubería y artefactos intermedios.

Motor de análisis estático

El motor estático analiza binarios PE (nativos y .NET) y ELF, extrayendo importaciones, cadenas (estándar y decodificadas por FLOSS [11]), secciones, coincidencias YARA y características de entropía. Para muestras empaquetadas como instalador (NSIS, Inno, MSI) realiza una extracción en varias pasadas: se extrae cada fichero incluido, las claves se descubren en *todos* los ficheros extraídos antes de intentar ningún descifrado (de modo que una clave incrustada en un componente pueda descifrar una carga en otro), las claves candidatas se prueban contra cualquier fichero que parezca cifrado, y todos los ficheros, descifrados o no, se analizan completamente después. La §5.2 detalla un error real encontrado y corregido en cómo funcionaba antes esta agregación.

Las reglas de detección mapean evidencia estática a técnicas ATT&CK mediante tres mecanismos complementarios:

- **Tablas de importaciones/cadenas.** Un mapeo curado de nombres de API de Windows o patrones de cadena específicos a identificadores de técnica.
- **Comprobaciones de combinación.** Para técnicas cuyo indicador individual más fuerte también es común en software legítimo, una regla exige una *combinación coherente* específica de indicadores antes de reportar confianza elevada. La Tabla 1 enumera todas las comprobaciones de combinación implementadas.
- **Llamadas a la BCL de .NET.** La tabla de importaciones nativas de un binario .NET suele ser únicamente el stub de arranque del CLR, así que los cuerpos de métodos gestionados se escanean directamente en busca de llamadas a APIs específicas de la Base Class Library (p. ej. `Convert::FromBase64String`).

Motor de análisis dinámico

La detonación dinámica se ejecuta dentro de CAPE [3] contra una red simulada con INetSim, aislada y sin salida real a Internet, un diseño de contención prioritaria cuya consecuencia para la observabilidad se discute en §6. El informe en bruto de CAPE se depura en un JSON más pequeño, centrado en IOCs: firmas, ficheros soltados, actividad de red y una lista curada de mapeos ATT&CK.

Las firmas de la comunidad de CAPE llevan sus propias etiquetas de técnica, pero se trataron como una hipótesis, no como verdad de referencia, durante toda la validación. La capa de curación mantiene tres tablas de corrección, cada entrada justificada individualmente frente a la evidencia en bruto de la propia firma (su campo `data`, no solo su nombre o categoría):

- **Firmas poco fiables,** descartadas por completo: p. ej. `unbacked_process_mitigation_alteration` (etiqueta T1562), cuyas direcciones de llamada en bruto en la muestra que la activó se sitúan todas en un rango estrecho de memoria alta consistente con una DLL del sistema, lo que sugiere que la clasificación de “memoria sin respaldo” falló sobre la propia inicialización automática de procesos de Windows en lugar de sobre la acción de la propia muestra.

Técnica	Combinación requerida	Rechazado en solitario
T1055 (Process Injection)	VirtualAllocEx + WriteProcessMemory + CreateRemoteThread, o el trío de lectura OpenProcess + VirtualQueryEx + ReadProcessMemory	OpenProcess en solitario
T1055.012 (Process Hollowing)	CreateProcessW + WriteProcessMemory + SetThreadContext + ResumeThread + Nt/ZwUnmapViewOfSection	cualquier API individual
T1562.001 (Impair Defenses)	WTSEnumerateProcessesW + OpenProcess + TerminateProcess	TerminateProcess sola
T1010 (Application Window Discovery)	EnumWindows + GetWindowTextW	GetWindowTextW sola
T1134.001/.003 (Impersonation/Theft; Make and Impersonate Token)	ImpersonateLoggedOnUser + DuplicateTokenEx (.001) o LogonUserW (.003)	Impersonate-LoggedOnUser sola

Cuadro 1: Reglas de detección sensibles a combinación. Un componente listado como “rechazado en solitario” se excluye deliberadamente de la promoción de confianza por importación única porque tiene un uso legítimo sustancial fuera de la técnica afirmada.

- **Eliminaciones de técnica por firma**, donde una etiqueta en una firma por lo demás fiable es incorrecta: p. ej. `antiav_servicestop` etiqueta T1489 (Service Stop), pero en la muestra que la activó, sus propios datos en bruto nombran el servicio concreto detenido: el propio driver de la muestra, no el de un producto de seguridad.
- **Reasignaciones de técnica**, donde las propias definiciones de MITRE contradicen la etiqueta de la comunidad: p. ej. `unbacked_api_resolution` está etiquetada por la comunidad como T1129 (Shared Modules), que la propia página de MITRE define como un módulo respaldado por un fichero en disco; la descripción de la propia firma (“memoria asignada dinámicamente, sin respaldo”) es exactamente lo contrario, y T1620 (Reflective Code Loading) encaja en su lugar.

Una capacidad adicional, añadida durante la ampliación de cobertura, comprueba los `executed_commands` en bruto de CAPE frente a patrones de comandos LOLBin/reconocimiento conocidos que no tienen ninguna firma de comunidad correspondiente: p. ej. `netsh wlan show profiles`, que CAPE observa y registra pero no mapea por sí mismo a ninguna técnica.

Reconciliación de confianza

La regla central de reconciliación (§3.4, implementada en `reconcile.py`) es: una técnica observada tanto por evidencia estática como dinámica alcanza confianza *alta*, salvo que la mejor confianza propia de ambas fuentes sea *baja*, en cuyo caso queda en *media*; una técnica observada por una sola fuente mantiene el nivel propio de esa fuente, y no puede promocionarse por volumen de evidencia de una única fuente.

Extensión entre niveles

Esta regla, tal como se implementó originalmente, comparaba observaciones agrupadas por identificador de técnica *exacto*. En la práctica, una firma dinámica frecuentemente reporta una técnica padre (p. ej. T1547) mientras que una regla estática reporta la subtécnica específica responsable (T1547.001): el mismo mecanismo de persistencia subyacente, observado en dos niveles de especificidad distintos por dos fuentes distintas, pero que nunca se corroboran entre sí bajo un agrupamiento por coincidencia exacta. Esta es una inconsistencia real, no hipotética: el propio emparejamiento a nivel de familia del arnés de evaluación (§4) ya trata una técnica padre y su subtécnica como equivalentes a efectos de puntuación, mientras que el modelo de confianza que produce el resultado puntuado no aplicaba el mismo principio.

`apply_cross_level_corroboration()` cierra este hueco: tras la pasada normal de reconciliación

por técnica, las técnicas se agrupan por identificador base (quitando cualquier sufijo de subtécnica), y para cualquier grupo donde exista evidencia estática *y* dinámica entre sus miembros pero a un miembro individual le falte una de las dos, su confianza se recalcula usando el mejor nivel del grupo para el lado que falta, la misma regla de “alta salvo que ambas sean bajas”, extendida entre identificadores hermanos en lugar de solo dentro de uno. Cada promoción queda registrada en el propio registro de la técnica (qué técnica hermana aportó la corroboración que faltaba), de modo que el mecanismo es auditable en lugar de mezclar evidencia entre identificadores de forma silenciosa. En las tres muestras validadas este cambio no alteró ningún valor final de confianza: cada grupo con granularidad mixta actualmente alcanzaba ya *alta* de forma independiente por la propia severidad de su fuente, o ambos miembros compartían la misma única fuente. Con todo, se construyó *antes*, no después, de la ampliación de cobertura descrita a continuación, precisamente porque las nuevas reglas estáticas específicas de subtécnica combinadas con firmas de comunidad de CAPE frecuentemente a nivel de técnica padre hacen que este hueco sea más probable en adelante, no menos.

El bucle de reenvío

La capacidad real del malware multietapa suele distribuirse entre varios binarios: RoningLoader, por sí solo, a lo largo de su cadena de infección suelta o carga reflexivamente un driver rootkit en modo kernel, una DLL cuya única función es enumerar y terminar productos de seguridad, y un cliente troyano de acceso remoto independiente (§5.1). Fusionar ingenuamente la evidencia de cada componente soltado en el propio `attck_mapping.json` de la muestra padre atribuiría mal la confianza: el modelo de `reconcile.py` asume que toda observación agrupada bajo una técnica describe el *mismo* binario, y una carga soltada no demuestra que el cargador padre presente ese comportamiento.

El bucle de reenvío, en cambio, hace pasar a cada componente soltado/extraído por su propia ejecución completamente independiente a través de la misma tubería de análisis estático → normalización → mapeo, etiquetada con linaje explícito (hash del padre, mecanismo de descubrimiento, marca de tiempo de descubrimiento) hacia la muestra que la produjo. Tres componentes, divididos por dependencia y no por conveniencia:

1. **Escritor de manifiesto** (se ejecuta en el host, solo con biblioteca estándar): localiza los bytes de ficheros soltados en el propio almacenamiento de resultados de CAPE, los copia a una cola, y escribe un manifiesto de linaje por candidato, acotado por un límite configurable de artefactos.
2. **Procesador estático** (se ejecuta dentro del contenedor de análisis estático, que ya tiene las dependencias más pesadas, `pefile`, `yara-python`, `FLOSS`, `Ghidra`, que necesita el análisis de ficheros soltados): analiza cada artefacto en cola y etiqueta su informe con los datos del manifiesto de linaje. Duplicar esas dependencias en un contenedor separado y más ligero se consideró y se descartó por ser superficie de mantenimiento innecesaria sin beneficio de aislamiento.
3. **Procesador de fusión** (se ejecuta dentro del contenedor de la tubería, solo con biblioteca estándar): localiza cada informe etiquetado con linaje que aún no se haya normalizado ni mapeado, y lo hace pasar por la misma tubería de reconciliación de confianza que una muestra de nivel superior, escribiendo en una ruta de salida específica del componente, nunca en el propio `attck_mapping.json` de la muestra padre, de modo que la evidencia de un componente soltado nunca pueda sobrescribir o mezclarse silenciosamente con el propio resultado puntuado del padre. Esto impone a nivel de sistema de ficheros el mismo principio de no mezcla que `reconcile.py` impone a nivel de modelo de datos.

Para RoningLoader en concreto, el bucle de reenvío descubrió y analizó de forma independiente 26 componentes más allá del propio binario cargador padre: el driver rootkit, la DLL antiavivirus y el cliente RAT, cada uno con su propia entrada dedicada en la verdad de referencia manual, más otros 23 artefactos adicionales de carga y configuración extraídos sin verdad de

referencia propia redactada individualmente. La Sección 4 puntúa los tres componentes nombrados frente a su verdad de referencia por componente, ya que puntuar solo el componente padre subestima estructuralmente lo que encuentra la tubería completa, incluyendo el bucle de reenvío; los 23 restantes son superficie de evaluación real adicional en un sentido distinto (§6, punto 1), cada uno confirmado como productor de un resultado sensato, sin caídas y etiquetado con linaje, en lugar de aportar nuevos puntos de datos de precisión/exhaustividad puntuados.

Ampliación de la cobertura de reglas de detección

Cada regla estática presente al inicio de la validación descrita en §4 existía porque evidencia específica en una de las tres muestras validadas la justificaba, un enfoque sólido para evitar el sobreajuste, pero que deja una cobertura estrecha respecto a la matriz completa de MITRE ATT&CK, no solo respecto a lo que necesitan individualmente las tres familias validadas. Para cuantificar esto con precisión en lugar de estimarlo, se descargó el paquete STIX oficial actual de MITRE Enterprise ATT&CK [12] y se contó directamente: 474 técnicas relevantes para Windows (incluyendo subtécnicas) en la matriz actual, de las cuales aproximadamente 30 tenían una regla estática dedicada antes de esta ampliación.

La cobertura se amplió posteriormente a lo largo de seis lotes, de una a dos tácticas cada vez, añadiendo aproximadamente 55 identificadores de técnica adicionales (listado completo en el Anexo A). Cada adición sigue la misma disciplina de procedencia: el patrón de detección es el mecanismo *literal* que nombra la propia descripción de la técnica en MITRE (un valor de registro específico, una combinación de clases WMI, un marcador de fichero, una DLL, o un indicador de línea de comandos), nunca una API o herramienta genérica por sí sola cuando ese nombre también tiene usos legítimos habituales. Tras cada lote, se volvió a ejecutar el análisis estático en las tres muestras validadas y se comprobó que no surgiera ningún hallazgo nuevo antes de considerar seguro conservar el lote; ninguna de las 55 adiciones se activó en ninguna de las tres muestras, confirmando que la ampliación no introduce nuevo riesgo de falsos positivos en el conjunto sobre el que se miden las cifras de este proyecto. Se trata explícitamente de cobertura orientada a muestras aún no vistas; no mueve, ni se afirma que mueva, las cifras de evaluación reportadas en §4.

La ampliación de cobertura se acotó deliberadamente, no de forma exhaustiva, tras comprobar el número real de técnicas para cada táctica restante de MITRE (§7): Reconnaissance y Resource Development quedan estructuralmente fuera de alcance sin importar el esfuerzo, ya que ambas describen actividad del atacante que ocurre antes de que la muestra de malware exista; Initial Access y Lateral Movement están técnicamente dentro de alcance pero encajan mal con lo que puede observar un análisis de detonación de un solo binario.

Despliegue y reproducibilidad

El prototipo y cada entorno de análisis del que depende, no solo el código propio de la tubería, está definido en un único `docker-compose.yml`, dividido en dos perfiles activables de forma independiente. El perfil `core` (motor de análisis estático, tubería, ATT&CK Navigator) no necesita configuración a nivel de host más allá de Docker en sí, y es el que produjo todos los resultados solo-estáticos de esta tesis. El perfil `sandbox` (CAPE, MISP y sus servicios de apoyo: MySQL, Redis, INetSim) necesita además una configuración manual única del host (libvirt/KVM y una máquina virtual Windows invitada instantánea), ya que la imagen de disco de una VM no puede aprovisionarse con `docker-compose`. La Tabla 2 enumera cada servicio y su perfil.

El único paso de configuración que `docker-compose` genuinamente no puede realizar es aprovisionar el hipervisor KVM/libvirt y su red virtual en el propio host, ya que `cape` e `inetsim` necesitan un `/dev/kvm` real y un puente libvirt real al que conectarse, no un namespace de contenedor. `scripts/host-prereqs.sh` automatiza este paso único y es idempotente: instala `qemu-kvm` y `libvirt`, verifica que `/dev/kvm` sea realmente utilizable, y descubre la interfaz puente, la subred y la IP de puerta de enlace que libvirt está usando en esa máquina concreta (deliberadamente no codificado de forma fija, ya que varía de host a host), escribiendo los valores descubiertos en

Servicio	Perfil	Función	Memoria
static	core	Motor estático PE/ELF (pefile , YARA, FLOSS, Ghidra headless)	3g
pipeline	core	Normalizador, mapeador, exportador (STIX/-MISP)	1g
navigator	core	Visualización de capas del ATT&CK Navigator	512m
redis	sandbox	Backend de sesión/trabajos de MISP	256m
inetsim	sandbox	Red simulada para la detonación, sin salida real	256m
cape	sandbox	Controlador del sandbox CAPE (detonación KV-M/libvirt)	6g
mysql	sandbox	Almacenamiento relacional de MISP	1g
misp	sandbox	Núcleo de MISP (almacenamiento de eventos, API, datos de galaxia)	2g

Cuadro 2: Inventario de servicios por perfil, a partir de `docker-compose.yml`.

`.env` para que `inetsim` y la propia interpolación de configuración de CAPE puedan recogerlos sin reconstruir la imagen.

Dos decisiones de diseño más en el fichero de composición se derivan directamente de la postura de contención prioritaria descrita en §3.3. Primero, los servicios de backend (análisis estático, tubería, MySQL, Redis) se sitúan en una red Docker con `internal: true` y sin ninguna ruta hacia el host ni hacia internet; solo MISP y el ATT&CK Navigator, los dos servicios que un humano necesita alcanzar desde un navegador, se sitúan en una segunda red no interna, manteniendo el límite de no salida en el punto más estrecho que todavía permite a un humano revisar los resultados. Segundo, CAPE e INetSim se ejecutan con red de host en lugar de en la red de backend aislada, una excepción deliberada y acotada: la detonación de CAPE basada en KVM/libvirt no tiene ningún patrón de despliegue Docker oficialmente soportado, y todo enfoque de la comunidad converge en red de host para el propio controlador del sandbox, de modo que el límite de no salida se impone una capa más abajo, en la propia configuración de red de la VM invitada, en lugar de en la capa Docker para este servicio concreto. Ejecutar ambos perfiles juntos en un host de 16GB se acerca a unos 14GB, algo que solo encaja porque la detonación es secuencial, una VM invitada cada vez, nunca concurrente.

Evaluación

Metodología

La verdad de referencia de cada una de las tres familias se produjo mediante ingeniería inversa manual, documentada como un informe de analista completo y nunca derivada del propio resultado de la tubería. Esta independencia es una salvaguarda metodológica deliberada, no un detalle incidental: ambos motores dependen de herramientas de terceros (YARA, FLOSS, firmas de la comunidad de CAPE) que pueden por sí mismas mapear mal una técnica, de modo que la verdad de referencia tuvo que establecerse sin consultar los propios artefactos extraídos por la tubería, ya que de lo contrario validar la tubería frente a ella sería circular. En concreto, el mismo protocolo se aplicó a las tres familias, en este orden, y solo el último paso llega a tocar el resultado propio de la tubería:

1. **Desensamblado estático independiente.** Cada muestra se cargó en Ghidra y se descompiló función por función, cada función de interés renombrada para reflejar su propósito establecido, sin consultar la propia extracción de importaciones o cadenas de la tubería.
2. **Observación dinámica independiente.** La detonación en sandbox se observó directamente (secuencia de llamadas a API, archivos soltados, actividad de red), registrando el comportamiento a partir de la traza en bruto en lugar de a través de las propias etiquetas de firma de la comunidad de CAPE, que §3.3 documenta como necesitadas de curación por sí mismas.
3. **Recuperación independiente de configuración y claves.** Cuando una muestra cifraba

u ofuscaba su configuración, la clave o el algoritmo se recuperó manualmente, completamente separado de los propios módulos automatizados de fuerza bruta y recuperación XOR de la tubería.

4. **Solo entonces, la comparación.** Se ejecutó la tubería y se comparó su `attck_mapping.json` con la tabla de Técnicas ATT&CK del informe terminado y producido de forma independiente (la auditoría de falsos positivos, §4.3). Por construcción, cada discrepancia que encuentra es un desacuerdo entre dos artefactos producidos de forma independiente, no la tubería comprobada frente a sus propias suposiciones.

La Tabla 3 da un ejemplo concreto por familia de evidencia que este protocolo recuperó y que la tubería automatizada nunca toca, que es lo que convierte cada informe en una comprobación independiente y no en una reformulación de lo que la herramienta ya asume.

Muestra	Recuperado de forma independiente, la tubería no lo toca
Akira	Tabla ATT&CK de 17 filas construida a partir de descompilación de Ghidra a nivel de función de los mecanismos internos de threading, logging y cifrado de la muestra.
RoningLoader	Los cuatro componentes de la cadena (instalador, <code>D3D11InstallHelper.dll</code> , driver rootkit, cliente RAT) descompilados por separado, incluyendo identificar <code>DoD3D11InstallUsingMSI</code> del auxiliar como una reimplimentación compilada en Rust de <code>env::var()</code> .
WhiteSnakeStealer	Clave RC4 recuperada mediante análisis de texto plano conocido, y el formato completo del paquete C2 <code>WSR\$</code> (XML de información del sistema cifrado con RC4 y comprimido con Deflate, con una clave envuelta en RSA) reconstruido directamente a partir del desensamblado.

Cuadro 3: Un ejemplo concreto por familia de evidencia recuperada de forma independiente para construir la verdad de referencia, aplicando el protocolo de cuatro pasos anterior.

La tabla de Técnicas ATT&CK de cada informe se analiza después para producir un fichero de verdad de referencia estructurado (`extract_ground_truth.py`), que el arnés de evaluación compara con el propio `attck_mapping.json` de la tubería.

Se reportan dos modos de emparejamiento. El emparejamiento *estricto* exige una coincidencia exacta de identificador de técnica. El emparejamiento a *nivel de familia* trata una técnica padre y cualquiera de sus subtécnicas como equivalentes (un hallazgo de la tubería de T1547.001 cuenta frente a una entrada de verdad de referencia de T1547 y viceversa), bajo la premisa de que un analista de seguridad que decide qué hacer ante un mecanismo de persistencia se preocupa primero por *qué* familia de táctica y técnica está presente, siendo la granularidad de subtécnica un refinamiento y no un hallazgo distinto. Se calculan precisión, exhaustividad y F1 bajo ambos modos para cada muestra; la Tabla 4 reporta las cifras a nivel de familia, siendo las cifras más estrictas materialmente más bajas solo donde realmente no se distinguió una subtécnica concreta.

Resultados

Las dos filas de RoningLoader aíslan exactamente lo que aporta el bucle de reenvío (§3.5): puntuar únicamente el binario cargador frente a una verdad de referencia escrita para *toda* su cadena de infección subestima la exhaustividad por construcción, ya que las técnicas propias del driver rootkit y del cliente RAT son hallazgos reales que la verdad de referencia espera pero que el binario padre por sí solo no puede presentar. La exhaustividad sube 16 puntos en cuanto se analizan de forma independiente los tres componentes soltados y se cuentan sus hallazgos, a un coste de 2 puntos de precisión por la superficie añadida, una compensación que la mejora del F1 agregado ($0.78 \rightarrow 0.86$) demuestra que mereció la pena.

Muestra	Precisión	Exhaustividad	F1	Notas
Akira (ransomware)	1.00	1.00	1.00	binario de una sola etapa
WhiteSnakeStealer (.NET)	1.00	0.80	0.89	binario de una sola etapa
RoningLoader (solo padre)	0.90	0.68	0.78	solo el cargador
RoningLoader (+reenvío)	0.88	0.84	0.86	cargador + 3 componentes soltados

Cuadro 4: Precisión/exhaustividad/F1 a nivel de familia por muestra validada.

La precisión está en o cerca de 1.00 en las cuatro filas, es decir, el pequeño número de hallazgos que reporta la tubería rara vez son erróneos. Esta es la consecuencia directa e intencionada de la filosofía de combinación coherente de §3.2 y la disciplina de curación de firmas de §3.3: ambas sacrifican algo de exhaustividad a cambio de alta confianza en que lo que *se* reporta es fiable, algo que la auditoría de falsos positivos a continuación existe para comprobar, no para asumir.

La auditoría de falsos positivos

La precisión por sí sola no distingue “la tubería está bien calibrada” de “la verdad de referencia resulta ser permisiva”. A diferencia de un agregador de reputación que muestra la etiqueta de cada motor o sandbox tal cual, cada discrepancia entre el resultado de la tubería y la verdad de referencia encontrada en las tres muestras, 13 en total (4 Akira, 4 WhiteSnakeStealer, 5 RoningLoader), se rastreó individualmente hasta una causa concreta y verificable en lugar de aceptarse o descartarse solo por la cifra agregada. Cada una se contrastó con el *texto completo* del informe manual correspondiente, no solo con su tabla resumen, ya que una técnica puede estar genuinamente discutida en la narrativa de un informe sin aparecer en su propia tabla ATT&CK.

El resultado de esta auditoría, por causa:

- **Diez errores genuinos de la tubería**, cada uno corregido en su causa raíz: tres mapeos de regla estática que no correspondían con la definición real de MITRE para la técnica afirmada (p. ej. `GetSystemInfo` mapeada a Descubrimiento de Información del Sistema, T1082, cuando la propia definición de MITRE trata específicamente sobre detección de *virtualización/sandbox*, T1497); un hueco en una comprobación de combinación que permitía que una única importación genérica activara T1055 por sí sola; y seis mapeos de firmas de la comunidad de CAPE cuyo propio campo de evidencia en bruto, al inspeccionarlo, nombraba un objetivo inconsistente con la técnica afirmada (detallado en §3.3).
- **Un hueco de extracción de verdad de referencia**, no un error de la tubería: el propio informe manual de WhiteSnakeStealer discute la carga reflexiva de DLL en su texto narrativo, pero la fila correspondiente de T1620 faltaba en la tabla ATT&CK del propio informe, de modo que la extracción automática de verdad de referencia nunca la capturó. El hallazgo de la tubería era correcto; se corrigió el documento fuente en lugar de la tubería.
- **Dos dejados abiertos deliberadamente**, en RoningLoader (T1027, T1497): la evidencia de apoyo de la tubería para ambos es real, pero no existe confirmación explícita del analista en ningún lugar del texto del informe, a diferencia del caso de T1620 anterior. Editar la verdad de referencia solo con la evidencia propia de la tubería, sin confirmación textual independiente, sería circular. Ambos permanecen como hallazgos abiertos en lugar de resolverse en un sentido u otro.

Esta asimetría, un hueco de verdad de referencia corregido y dos discrepancias de aspecto similar dejadas abiertas, es deliberada: el factor distintivo es si existe confirmación independiente en el documento fuente, no si la evidencia propia de la tubería parece convincente. El resultado práctico de ejecutar esta auditoría se aprecia en la columna de corregidos: 10 de las 13 discrepancias se tradujeron en mejoras concretas y verificables al conjunto de reglas (§3.6) y a la lógica de agregación (§5.2) en lugar de absorberse en silencio dentro de una cifra agregada, precisamente el paso diagnóstico que una visualización de veredictos uno junto a otro no puede ofrecer.

Calibración de confianza

Si el modelo de reconciliación de confianza (§3.4) es significativo y no meramente cosmético, la precisión debería ser medible y mayor entre los hallazgos de confianza *alta* (aquellos corroborados entre fuentes o entre niveles de técnica) que entre los hallazgos de *media/baja* de una sola fuente. En las tres muestras validadas, cada falso positivo identificado en la auditoría anterior tuvo su origen en un hallazgo de una sola fuente; ningún hallazgo que alcanzara confianza *alta* mediante corroboración entre fuentes o entre niveles estuvo entre las 13 discrepancias investigadas. Esto es consistente con que el modelo de reconciliación realiza una calibración real y no simplemente reetiqueta hallazgos, aunque el tamaño reducido de la muestra (tres familias) implica que esto debe leerse como una señal direccional, no como una afirmación con potencia estadística, una limitación enunciada explícitamente en §6.

Casos de estudio

Las cifras agregadas (§4) muestran *que* la tubería rinde bien; los cuatro casos siguientes muestran *por qué*: instancias concretas de la disciplina de validación encontrando y resolviendo un problema real, cada una ilustrando una clase de fallo distinta que una evaluación puramente numérica no sacaría a la luz por sí sola.

La cadena multietapa de RoningLoader

La cadena de infección de RoningLoader, establecida mediante ingeniería inversa manual, no es un binario sino cuatro: un cargador que descifra y suelta un driver rootkit en modo kernel usado para ocultar su propio proceso y ficheros, una DLL independiente cuya única función es enumerar y terminar productos de seguridad, y un cliente de acceso remoto que establece el canal C2 real. La capacidad de cada componente es real y significativa por sí misma; ninguno de los tres componentes soltados aparece como importación o cadena en el propio binario cargador, ya que se descifran en memoria o se sueltan a disco únicamente en tiempo de ejecución.

La Tabla 4 ya muestra la consecuencia numérica: puntuar el cargador de forma aislada alcanza una exhaustividad de 0.68 frente a una verdad de referencia escrita para la cadena completa, porque aproximadamente un tercio de las técnicas que un analista humano atribuye correctamente a la familia “RoningLoader” solo son observables analizando directamente los componentes soltados. El bucle de reenvío (§3.5) existe precisamente porque esto es una propiedad estructural del malware multietapa, no una peculiaridad de una muestra, y cierra 16 de esos 32 puntos de exhaustividad al dar a cada componente su propio análisis independiente en lugar de intentar inferir su capacidad a partir de la evidencia del padre.

El error de agregación del instalador

Al principio de la validación, el informe estático de una muestra empaquetada como instalador mostraba evidencia consistente solo con *uno* de sus varios componentes incluidos, pese a que la lógica de extracción en varias pasadas (§3.2) había procesado todos ellos. Al trazar directamente el código de generación del informe, sin asumir que el fallo estaba en la propia lógica de extracción, se encontró el defecto real una etapa después: `_analyze_installer`, la función que agrega los resultados por componente en el informe único de nivel superior de la muestra, estaba *sustituyendo* silenciosamente el análisis de un componente hijo por el de otro bajo una condición específica, en lugar de fusionar ambos.

El error se confirmó, no solo se infirió del síntoma, a través del propio campo `hash_match` del informe, un valor registrado precisamente para este tipo de comprobación cruzada, que mostraba que el hash reportado pertenecía a un fichero extraído distinto del que realmente aparecía en el cuerpo del informe. Corregir la lógica de agregación para fusionar los hallazgos de cada componente extraído, en lugar de solo el procesado más recientemente, restauró la evidencia faltante y mejoró directamente la exhaustividad en la muestra afectada tras volver a evaluarla.

La lección se generalizó más allá de esta corrección concreta: motivó tratar cada nueva ca-

pacidad de la tubería, el bucle de reenvío en primer lugar, como necesitada de su propio paso explícito de corroboración (manifiestos de linaje, comprobaciones cruzadas de hash) en lugar de confiar en que “el código se ejecutó sin error” implique “el código produjo el resultado correcto”. Encontrar y corregir esta clase de error antes de que pudiera subestimar en silencio la capacidad real de una muestra es en sí mismo una demostración concreta de para qué sirve la disciplina de validación de la tubería.

El hueco de verdad de referencia de WhiteSnakeStealer

La §4.3 resume el resultado; el proceso merece detallarse una vez como ejemplo concreto de lo que significa en la práctica “auditado frente al texto completo del informe”. El resultado de la tubería para WhiteSnakeStealer incluía T1620 (Reflective Code Loading) con evidencia estática, llamadas específicas a la BCL de .NET consistentes con la carga de ensamblados en memoria. La propia tabla de Técnicas ATT&CK de la muestra, sin embargo, no tenía fila de T1620, por lo que la evaluación automática inicialmente puntuó esto como un falso positivo.

Al leer la sección narrativa del informe, en lugar de confiar solo en su tabla resumen, se encontró un párrafo explícito que describía exactamente el mecanismo de carga reflexiva que había detectado la regla estática: existía confirmación independiente del analista, simplemente no se había trasladado a la tabla que lee el extractor automático de verdad de referencia. Esto es un hueco de documentación en el informe fuente, no un error de la tubería, y se corrigió añadiendo la fila que faltaba al propio informe (y regenerando la verdad de referencia a partir de él), en lugar de ajustar la confianza de la tubería o suprimir el hallazgo. Se presenta aquí específicamente porque dos casos estructuralmente similares en RoningLoader (§4.3) se resolvieron en el sentido opuesto, dejados abiertos, precisamente porque les faltaba este tipo de confirmación textual independiente. Juntos, los dos desenlaces muestran que la evidencia propia de la tubería se trata igual independientemente de si la discrepancia terminó favoreciéndola.

La cascada de falsos positivos de la clave XOR

La fuerza bruta XOR de un solo byte (`config_parser.py`) prueba exhaustivamente las 256 claves posibles contra regiones candidatas de texto cifrado y compara el resultado con una expresión regular de IP en formato punteado, la técnica que recuperó la IP de C2 genuína de RoningLoader (202.95.11.173) sin conocimiento previo de la clave (§6, punto 7). Ejecutada sin salvaguardas contra una segunda muestra, WhiteSnakeStealer, la misma rutina produjo 8 coincidencias de cuarteto punteado sintácticamente válidas pero completamente espurias a partir de una única clave incorrecta (0x2e, ASCII .): una tabla de enteros repetitiva con relleno de ceros en los datos compilados del binario resultó decodificar a ocho direcciones IP falsas bajo esa única clave, ya que los bytes nulos se decodifican como caracteres . literales bajo ella y una estructura repetitiva en los datos de origen produce una coincidencia falsa repetitiva.

Dos filtros cerraron el hueco, cada uno justificado por una propiedad distinta que un valor incrustado genuino tiene y un accidente de decodificación no. Primero, una **comprobación de límite limpio**: el byte inmediatamente anterior y posterior a una coincidencia debe ser 0x00 o el propio byte de clave, algo que una cadena real incrustada y terminada en nulo cumple y que una secuencia de bytes arbitraria decodificada por una clave no relacionada generalmente no. Segundo, un **límite de densidad de coincidencias** de dos coincidencias con forma de IP por clave en cualquier lugar del fichero, bajo el principio de que un valor de configuración genuino aparece una vez, o raramente un puñado de veces, mientras que una cascada producida al decodificar datos estructurados no relacionados bajo la clave equivocada no se autolimita. Verificado después en ambas direcciones: la IP de C2 genuína de RoningLoader sigue produciendo exactamente una coincidencia y sobrevive al límite de densidad; las ocho coincidencias espurias de WhiteSnakeStealer ahora se descartan correctamente.

La lección se generalizó más allá de esta corrección concreta: es lo que motivó la política explícita del proyecto (§6, punto 9) de que cualquier nueva capacidad de recuperación basada en búsqueda exhaustiva debe validarse frente a una segunda muestra, no solo la que motivó su

construcción, antes de confiar en ella. De haberse declarado esta capacidad lista para producción solo con RoningLoader, la tubería habría salido con un generador de falsos positivos que simplemente todavía no se había activado.

Limitaciones

Enunciar las limitaciones con esta precisión es en sí mismo parte de la contribución argumentada en §2: los veredictos uno junto a otro de un agregador de reputación no llevan un relato equivalente de dónde podrían estar equivocados, lo que los hace rápidos de consultar pero difíciles de auditar. Cada limitación siguiente se diagnostica, en cambio, a una causa concreta y verificable en lugar de enunciarse de forma genérica, de modo que cada una ya está mitigada de forma concreta o se acota como un siguiente paso preciso (§7) en lugar de quedar como una advertencia abierta.

1. **Conjunto de validación pequeño (N=3).** Tres familias son pocas para una afirmación con potencia estadística, y es el punto que más merece escrutinio en este trabajo. Tres mitigaciones concretas: la verdad de referencia es ingeniería inversa manual a nivel de función, verificada con Ghidra, para cada muestra, un listón considerablemente más alto que el que tendría un conjunto más grande pero superficial; una auditoría completa de `static/scripts/` centrada específicamente en hardcoding específico de muestra disfrazado de lógica genérica encontró y eliminó cuatro instancias (un nombre de fichero literal del auxiliar del instalador, una extensión de carga cifrada codificada de forma fija, cadenas de producto incrustadas en la lógica de detección de sistema de ficheros, y un decodificador “genérico” que en realidad era la clave XOR exacta de una muestra), cada una sustituida por un equivalente a nivel de clase y reverificada para no provocar regresión en ninguna muestra validada; y el bucle de reenvío de RoningLoader (§3.5) puntúa de forma independiente 26 componentes adicionales frente a la misma verdad de referencia, superficie de evaluación real adicional y no un truco estadístico. Ampliar a más familias sigue siendo el siguiente paso de mayor valor (§7).
2. **Un error de agregación, encontrado y corregido durante la validación.** Detallado como caso de estudio en §5.2: el informe estático de una muestra instalador describió una DLL auxiliar side-loaded incluida, no la carga maliciosa, durante la mayor parte del proceso de validación, hasta que se comprobó realmente el propio campo de sanidad `hash_match` del informe en lugar de solo calcularlo. La corrección mejoró directamente la exhaustividad en la muestra afectada.
3. **La auditoría de falsos positivos (§4.3)** comprobó 13 discrepancias individualmente; 10 eran errores genuinos de la tubería, ahora corregidos, 1 era un hueco de extracción de verdad de referencia (§5.3), y 2 permanecen abiertas por diseño.
4. **Dos falsos positivos de RoningLoader quedan sin resolver deliberadamente.** T1027 y T1497 tienen ambos evidencia real de apoyo pero ninguna confirmación textual independiente en el resto del informe manual, a diferencia del caso de T1620 que sí se corrigió. Editar la verdad de referencia solo con la evidencia propia de la tubería sería un razonamiento circular.
5. **La extracción de verdad de referencia depende de la completitud de la tabla.** Un extractor basado en tablas markdown solo es tan completo como la propia tabla, incluso cuando la narrativa de un informe dice más. §5.3 es una instancia concreta, corregida en el documento fuente en lugar de sortearse en el extractor.
6. **El sandboxing con contención prioritaria limita la observación de red/C2.** CAPE detona cada muestra contra la red simulada de INetSim, sin salida real, por diseño. Varias técnicas no detectadas en las tres muestras se agrupan en torno a comportamiento de exfiltración y proxy/túnel (T1041, T1090, T1571/T1572, T1046) que una red simulada no puede provocar por completo. Esto es una propiedad estructural de un entorno de investigación

con contención prioritaria, no un defecto a corregir.

7. **La recuperación estática de claves/configuración tiene un techo preciso.** El XOR de un solo byte es exhaustivamente forzable por fuerza bruta (128 claves), y así se usó para recuperar la IP de C2 de RoningLoader sin conocimiento previo de la clave, pero solo tras añadir dos filtros independientes de falsos positivos (§5.4). En cambio, la clave RC4 de una carga distinta, verificada de forma independiente mediante ingeniería inversa manual con Ghidra, se ensambla en *tiempo de ejecución* a partir de tres constantes combinadas mediante aritmética de registros y nunca existe como secuencia de bytes contigua en el fichero: ningún método estático de patrón de bytes, por exhaustivo que sea, puede recuperar una clave que nunca se almacena como bytes. El límite está precisamente en si la clave existe como bytes en disco, no en una afirmación general de que “el cifrado es difícil”.
8. **La verdad de referencia es el mejor oráculo disponible, no uno perfecto.** Un hallazgo automático ausente en un informe manual puede ser un falso positivo genuino o un verdadero positivo poco documentado (§5.3); un hallazgo documentado que la tubería no detecta puede ser un hueco real o un techo del entorno de sandbox (punto 6 anterior).
9. **Limitaciones a nivel de herramienta.** La decodificación de cadenas basada en emulación de FLOSS agotó el tiempo en Akira, la muestra más agresiva en anti-análisis, registrado explícitamente en lugar de faltar en silencio. La recuperación AES/ChaCha20 solo tiene éxito frente a un nonce/IV cero. Cualquier nueva capacidad de recuperación por fuerza bruta ahora se valida, por política explícita, frente a una segunda muestra antes de confiar en ella, tras detectarse así la cascada de falsos positivos de la clave XOR (§5.4) en lugar de al primer éxito.
10. **Reproducibilidad.** La §3.7 describe el despliegue completo con `docker-compose`; el único hueco que merece repetirse aquí es que la máquina virtual Windows del perfil `sandbox` necesita una configuración manual única del host (libvirt/KVM), documentada con sus propias notas de solución de problemas, ya que no puede crearse solo con `docker-compose`.
11. **La cobertura de reglas estáticas es deliberadamente estrecha.** Aproximadamente 85 de las 474 técnicas relevantes para Windows en MITRE tienen una regla estática dedicada (§3.6); Reconnaissance y Resource Development son un límite estructural, no una lista pendiente por abordar, ya que ambas describen actividad del atacante que precede a la existencia de la propia muestra.

Trabajo futuro

- **Familias adicionales validadas.** La extensión de mayor valor (§6, punto 1) es bien una validación completa respaldada por ingeniería inversa manual de más familias, o, como paso intermedio más ligero, una prueba de generalidad que confirme que la tubería produce un resultado sensato y sin caídas en familias frente a las que no se afinó.
- **Análisis dinámico Linux/ELF para familias de botnets IoT.** Investigado de forma concreta y no descartado por suposición, y aplazado deliberadamente por tres razones específicas, cada una verificada de forma independiente: el analizador ELF actual de la tubería extrae solo metadatos estructurales básicos, sin ninguna regla de detección ATT&CK conectada, a diferencia de la vía PE con sus aproximadamente 85 técnicas mapeadas; la propia documentación de CAPE describe su soporte de sandboxing Linux/ELF como una capacidad en desarrollo activo, no de nivel producción; y todavía no existe ninguna muestra de familia ELF con verdad de referencia frente a la que verificar cualquier nueva regla de detección específica de Linux, sin lo cual construir reglas repetiría exactamente el riesgo de sobreajuste que ya señala §6 para el lado Windows. Dado lo desproporcionadamente comunes que son las botnets basadas en ELF en dispositivos IoT y Linux embebido en comparación con la atención que les presta la propia literatura de investigación de malware, se considera una extensión genuinamente valiosa, pero una que primero necesita una

muestra de familia ELF validada y una capacidad real de análisis dinámico, no un conjunto de reglas reajustado sobre el análisis estático por sí solo.

- **Ampliar la cobertura de Initial Access y Lateral Movement donde encaje realmente.** La mayor parte de ambas tácticas encaja mal estructuralmente con el análisis de detonación de un solo binario (§3.6), pero queda un pequeño número de subtécnicas observables desde los propios artefactos de una muestra sin cubrir: T1091 (Replication Through Removable Media) y T1570 (Lateral Tool Transfer) son las dos candidatas concretas identificadas.
- **Un estudio de calibración de confianza con potencia estadística.** El hallazgo de §4 de que ningún falso positivo auditado se originó en un hallazgo de confianza alta corroborado entre fuentes o entre niveles es una señal direccional de tres muestras, no una afirmación con potencia estadística, y se beneficiaría de un conjunto de validación más grande y diseñado para ello.
- **Recuperación de claves en tiempo de ejecución mediante emulación.** La clave RC4 que nunca existe como bytes contiguos en la DLL de RoningLoader (§6, punto 7) es, en principio, recuperable emulando su rutina de ensamblado (p. ej. con Unicorn) en lugar de mediante cualquier búsqueda de patrón de bytes estática, un esfuerzo de ingeniería sustancialmente mayor que el módulo actual de recuperación estática de configuración, y fuera de alcance de esta tesis en consecuencia.

Conclusión

Esta tesis ha presentado MalWhere, una tubería que combina análisis estático y dinámico de malware para producir inteligencia de amenazas con confianza cuantificada y conforme a estándares: mapeos de técnicas MITRE ATT&CK exportados como paquetes STIX 2.1 y eventos MISP en vivo. Dos mecanismos la extienden más allá de un diseño estático-más-dinámico convencional: un modelo de reconciliación de confianza que reconoce concordancia tanto entre fuentes como entre niveles de especificidad de técnica (§3.4), y un bucle de reenvío que atribuye correctamente la capacidad distribuida de una muestra multietapa al componente que realmente la presenta, en lugar de colapsarla en la puntuación propia del binario padre (§3.5). Frente a las herramientas revisadas en §2, la tubería no pretende sustituir a un agregador de reputación amplio como VirusTotal, al que ningún pipeline de investigación de un solo equipo puede igualar en escala bruta de corpus de envíos; es el paso que viene después, convirtiendo esa primera señal en un mapeo reconciliado, por técnica y ligado a evidencia para la muestra concreta que realmente lo necesita.

Validada frente a tres familias de malware con arquitecturas sustancialmente distintas (un binario de ransomware de una sola etapa, un infostealer .NET rico en funcionalidades, y una cadena de cuatro componentes cargador/rootkit/RAT) contra verdad de referencia construida a partir de ingeniería inversa manual a nivel de función, la tubería alcanzó puntuaciones F1 a nivel de familia de 1.00, 0.89 y 0.86 respectivamente, con precisión cercana al 100 % en todos los casos (§4). Esas cifras solo son tan fiables como el proceso que las produjo, razón por la cual esta tesis otorga igual peso al rastro de auditoría que las respalda: 13 discrepancias entre el resultado de la tubería y la verdad de referencia se rastrearon individualmente hasta una causa concreta y verificable, no se aceptaron ni descartaron solo por la cifra agregada (§4.3); se encontró y corrigió un error real de agregación que había sustituido silenciosamente el binario analizado incorrecto (§5.2); y la cobertura de detección estática se amplió de unas 30 a aproximadamente 85 identificadores de técnica MITRE, cada adición obtenida de las propias descripciones de técnica de MITRE y confirmada para no introducir nuevos hallazgos en el conjunto validado antes de confiar en ella (§3.6).

El argumento central de este trabajo es que este rastro de auditoría, cada regla ligada a evidencia verificable, cada discrepancia diagnosticada a una causa concreta, cada extensión comprobada frente a regresiones antes de conservarse, es una contribución más defendible que las cifras F1 destacadas por sí solas, y es la propiedad con mayor probabilidad de transferirse cuando

la tubería se encuentre con una familia de malware para la que no ha sido afinada. Precisamente porque esa transferencia todavía no se ha medido, ampliar el conjunto de familias validadas (§7) se identifica como el siguiente paso de mayor valor, junto con la extensión concretamente acotada al análisis de botnets IoT basadas en Linux/ELF una vez que sus dos prerequisites faltantes, reglas de detección realmente conscientes de ELF y una muestra Linux con verdad de referencia, estén disponibles.

Referencias

- [1] MITRE Corporation, “MITRE ATT&CK.” <https://attack.mitre.org/>, 2026. Enterprise Matrix, accessed 2026.
- [2] MISP Project, “MISP: Open Source Threat Intelligence Platform.” <https://www.misp-project.org/>, 2026.
- [3] CAPE Sandbox Project, “CAPE: Config And Payload Extraction.” <https://github.com/kevoreilly/CAPEv2>, 2026.
- [4] Cuckoo Sandbox Project, “Cuckoo Sandbox: Automated Malware Analysis.” <https://cuckoosandbox.org/>, 2022.
- [5] Mandiant FLARE Team, “capa: The FLARE Team’s Open Source Tool to Identify Capabilities in Executable Files.” <https://github.com/mandiant/capa>, 2026.
- [6] G. Husari, E. Al-Shaer, M. Ahmed, B. Chu, and X. Niu, “TTPDrill: Automatic and Accurate Extraction of Threat Actions from Unstructured Text of CTI Sources,” in *Proceedings of the 33rd Annual Computer Security Applications Conference (ACSAC)*, 2017.
- [7] MITRE Engenuity Center for Threat-Informed Defense, “TRAM: Threat Report ATT&CK Mapper.” <https://github.com/center-for-threat-informed-defense/tram>, 2026.
- [8] V. Legoy, M. Caselli, C. Seifert, and A. Peter, “Automated Retrieval of ATT&CK Tactics and Techniques for Cyber Threat Reports.” <https://arxiv.org/abs/2004.14322>, 2020. arXiv:2004.14322.
- [9] VirusTotal (Google), “VirusTotal.” <https://www.virustotal.com/>, 2026.
- [10] OASIS Cyber Threat Intelligence Technical Committee, “STIX Version 2.1.” <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>, 2021.
- [11] Mandiant FLARE Team, “FLOSS: FLARE Obfuscated String Solver.” <https://github.com/mandiant/flare-floss>, 2026.
- [12] MITRE Corporation, “MITRE ATT&CK STIX Data (Enterprise).” <https://github.com/mitre/cti>, 2026. enterprise-attack.json, accessed 2026.

Ampliación de cobertura de reglas de detección

Listado completo, técnica por técnica, de los seis lotes de cobertura resumidos en §3.6. Cada fila se verificó tras añadirse para no activarse en ninguna de las tres muestras validadas, confirmando que la ampliación no altera la Tabla 4.

Técnica	Nombre	Mecanismo de detección
Lote 1: Persistence y Defense Evasion		
T1546.010	AppInit DLLs	cadena de registro AppInit_DLLs
T1547.004	Winlogon Helper DLL	cadena Winlogon\Shell\Userinit

continúa en la página siguiente

Técnica	Nombre	Mecanismo de detección
T1547.005	Security Support Provider	cadena Security Packages
T1547.002	Authentication Package	cadena Authentication Packages
T1546.012	Image File Execution Options Injection	cadena Image File Execution Options
T1546.003	WMI Event Subscription	cadenas __EventFilter/ __EventConsumer/ __FilterToConsumerBinding
T1197	BITS Jobs	cadena bitsadmin
T1070.001	Clear Windows Event Logs	cadena wevtutil cl
T1218.010	Regsvr32 (Squiblydoo)	cadena scrobj.dll
T1218.005	Mshta	mshta.exe + .hta (ambos requeridos)
T1055.012	Process Hollowing	combinación (§3.2, Tabla 1)
Lote 2: Credential Access y Collection		
T1003.001	LSASS Memory	importación MiniDumpWriteDump + cadena lsass.exe
T1003.002	Security Account Manager	cadena hklm\sam
T1003.004	LSA Secrets	cadena SECURITY\Policy\Secrets
T1552.002	Credentials in Registry	patrones de ruta de credenciales en registro
T1552.004	Private Keys	marcadores PEM/OpenSSH, .ppk
T1555.004	Windows Credential Manager	importación VaultOpenVault, cadena VaultCli.dll
T1556.002	Password Filter DLL	cadena Notification Packages
T1040	Network Sniffing	cadenas wpcap.dll/Packet.dll
T1125	Video Capture	cadena avicap32.dll
T1114.001	Local Email Collection	cadenas .ost/.pst
T1039	Data from Network Shared Drive	WNetOpenEnumW/A + WNetEnumResourceW/A + WNetCloseEnum
Lote 3: Execution y Command and Control		
T1053.005	Scheduled Task	cadena schtasks / patrón de comando
T1059.001	PowerShell (codificado/oculto)	-EncodedCommand + -WindowStyle Hidden (am- bos requeridos)
T1559.002	Dynamic Data Exchange	cadena DDEAUTO
T1127.001	MSBuild	cadena msbuild.exe
T1569.002	Service Execution	cadenas sc start/net start
T1102.002	Web Service (bidireccional)	api.telegram.org, pastebin.com/raw, raw.githubusercontent.com, discord.com/api/webhooks
T1572	Protocol Tunneling	Renci.SshNet, ngrok, serveo.net
T1090.002	External Proxy	cadena :9050 (puerto SOCKS de Tor)
Lote 4: Discovery		
T1518.001	Security Software Discovery	cadenas MsMpEng.exe / avp.exe / SecurityCenter2
T1049	System Network Connections Discovery	importaciones GetTcpTable / GetExtendedTcpTable / GetUdpTable
T1087.001	Local Account Discovery	importación NetUserEnum
T1018	Remote System Discovery	importación NetServerEnum
T1120	Peripheral Device Discovery	importación SetupDiGetClassDevsW/A
T1614.001	System Language Discovery	importaciones GetSystemDefaultLangID/ GetUserDefaultUILanguage
T1010	Application Window Discovery	combinación (§3.2, Tabla 1)
T1033	System Owner/User Discovery	importación GetUserNameW/A (trasladada desde T1082)
Lote 5: Impact		
T1529	System Shutdown/Reboot	importación ExitWindowsEx
T1531	Account Access Removal	importación NetUserChangePassword
T1561.001	Disk Content Wipe	cadena \\.\PhysicalDrive
T1496	Resource Hijacking	cadena stratum+tcp://
Lote 6: Privilege Escalation y Exfiltration		
T1134.001	Token Impersonation/Theft	ImpersonateLoggedOnUser + DuplicateToken(Ex)
T1134.002	Create Process with Token	importación CreateProcessWithTokenW
T1134.003	Make and Impersonate Token	ImpersonateLoggedOnUser + LogonUserW/A
T1548.002	Bypass User Account Control	cadena ms-settings \ Shell \ Open \ command
T1546.008	Accessibility Features	cadena sethc.exe
T1546.009	AppCert DLLs	cadena AppCertDlls
T1547.014	Active Setup	cadena Active Setup\Installed Components
T1098	Account Manipulation	cadena net localgroup administrators
T1567.001	Exfil. a repositorio de código	cadena api.github.com
T1567.002	Exfil. a almacenamiento en la nube	dropboxapi.com / storage.googleapis.com
T1567.003	Exfil. a sitios de almacenamiento de tex- to	pastebin.com / api / api_post.php
T1567.004	Exfil. por webhook	mapeo dual desde la evidencia de webhook de Discord de T1102.002

continúa en la página siguiente

Técnica	Nombre	Mecanismo de detección
T1048.003	Exfil. por protocolo no cifrado ajeno a C2	importación FtpPutFileW/A

Cuadro 5: 55 identificadores de técnica añadidos a lo largo de seis lotes de cobertura (§3.6), obtenidos de las propias descripciones de técnica de MITRE.